

Enterprise AI and Model Risk Management Policy

Meridian National Bank — Second Line of Defense, Model Risk Management Policy No. MRM-014 ·
Version 3.2 · Board Risk Committee approved · Owner: Chief Model Risk Officer Classification: Internal ·
Review cycle: Annual

1. Purpose and Scope

This Policy establishes the framework by which Meridian National Bank ("the Bank") governs model risk and artificial intelligence (AI) risk across the enterprise. It applies to all models and AI systems developed, purchased, or otherwise used by the Bank, including generative AI (GenAI) and agentic AI use cases.

The Bank is a covered organization under the interagency *Revised Guidance on Model Risk Management* (SR 26-2 / OCC 2026-x / FDIC). Where SR 26-2 excludes generative and agentic AI from the formal definition of "model," this Policy extends the Bank's established model-risk discipline to those systems under a dedicated **GenAI Governance Track** (Section 13), consistent with the guidance's direction that a banking organization's own risk-management and governance practices should determine appropriate controls for systems not formally in scope.

2. Definitions

- **Model** — a complex quantitative method applying statistical, economic, or financial theory to process input data into quantitative estimates. Excludes simple arithmetic, deterministic rule-based processes, and standalone spreadsheets (governed as End-User Computing).
- **AI system** — a system that infers, from input, how to generate outputs such as predictions, content, recommendations, or decisions.
- **GenAI use case** — a specific business application built on a foundation model (LLM). One foundation model may support many use cases with different risk profiles.
- **Foundation model** — a large pre-trained model (typically third-party) registered once as a shared component; individual use cases are registered and tiered separately.
- **Use case owner (first line)** — the accountable business owner of a specific AI application.

3. Framework References

SR 26-2 (Revised Guidance on Model Risk Management); SR 11-7 (legacy, retained for continuity mapping); NIST AI Risk Management Framework (AI 100-1); NIST Generative AI Profile (AI 600-1); ISO/IEC 42001:2023.

4. Model Risk Appetite and Materiality

Model risk is a function of **inherent risk** (complexity, assumptions, data quality, interpretability), **exposure** (financial footprint, population affected), and **purpose** (regulatory / consequential use ranks higher than internal decision support). Materiality = purpose × exposure. The Bank maintains a low appetite for un-tiered, un-inventoried, or un-validated consequential AI use.

5. Governance Structure — Three Lines of Defense

- **First line** — use-case owner / developer / business sponsor. Originates the use case, produces documentation, implements controls, monitors performance, and promptly registers new or changed use cases.
- **Second line** — Model Risk Management (this function), reporting to the Chief Risk Officer, independent of development. Owns policy, the inventory, tiering, independent validation, findings, and approval. Holds authority to challenge and to restrict or block deployment ("effective challenge").
- **Third line** — Internal Audit. Independently assesses whether the framework and its controls operate effectively. Does not develop or validate.

6. Model and Use-Case Inventory

All models and AI use cases must be registered in the enterprise inventory before validation and before production use. Foundation models are registered once as shared components with an AI Bill of Materials (AIBOM); each downstream use case is registered separately. The inventory is the system of record and the starting point for every lifecycle event.

7. Risk Tiering Methodology

Each use case is tiered at inception on materiality, consumer impact, autonomy (degree of human-in-the-loop), reversibility of outputs, and data sensitivity. Tiering drives validation intensity, approval authority, and monitoring cadence.

Tier	Trigger conditions (any)	Validation	Approval	Monitoring
Tier 1 (High)	Customer-facing or consequential decisions; regulatory / fair-lending exposure; high autonomy / limited human review; low reversibility; PII or sensitive data	Full independent validation incl. adversarial/red-team, bias, hallucination, and grounding testing	Model Risk Committee	Continuous; annual or event-driven revalidation
Tier 2 (Moderate)	Material internal impact; meaningful human oversight	Proportionate validation; targeted testing	Head of MRM	Periodic; ~biennial
Tier 3 (Low)	Low materiality and complexity; strong human-in-the-loop; reversible outputs	Lightweight review; core documentation	Use-case owner + MRM sign-off	Light; attestation-based, with a trigger to re-tier if use becomes material

Any use case that is customer-facing, drives consequential decisions, or processes PII is **Tier 1** irrespective of score.

8. Lifecycle

Registration → tiering → independent assessment → findings & remediation → approval / attestation → inventory entry → ongoing monitoring and periodic revalidation. Where a GenAI layer feeds an underlying traditional model that remains in formal scope, that underlying model stays in full validation scope.

9. Independent Validation and Effective Challenge

Validation scope is proportional to tier and covers conceptual soundness, outcomes analysis, and ongoing-monitoring review. For GenAI use cases, validation additionally tests the controls in Section 13. Deficiencies too severe to be addressed within the use case's framework require rejection; otherwise uncertainty must be mitigated by compensating controls.

10. Findings and Issues Management

Findings carry a severity (High / Medium / Low), a remediation owner (first line), and a target date. High-severity findings may block production or force compensating controls and are escalated to the Model Risk Committee. Approval states: approved / approved with conditions / approved with restrictions / not approved.

11. Third-Party and Foundation-Model Risk

Externally sourced foundation models require documented due diligence, an AIBOM (provenance, security posture, update cadence), contractual confirmation that Bank data is not used to train vendor base models, and a contingency plan for model deprecation or version change.

12. Documentation Standards

Each use case must maintain the minimum exam-defensible document set: intake/registration record, tiering worksheet, development documentation / model card, validation report, monitoring plan, approval record, inventory entry, findings log, third-party assessment, and data-governance/privacy sign-off.

13. GenAI-Specific Required Controls (Governance Track)

Every GenAI use case is assessed against the following eight controls. Each is rated **met**, **partial**, or **gap**, with cited evidence, and contributes to the risk tier and the control-gap scorecard.

1. **Hallucination / confabulation testing** — measured error rate against a defined threshold for the use case (NIST 600-1 §2.2).
2. **Prompt-injection / adversarial resistance** — red-team testing of direct and indirect injection; input filtering (NIST 600-1 §2.9).

3. **Data leakage / privacy** — DPIA on file; input filtering and output redaction; PII controls; data residency within the Bank perimeter (NIST 600-1 §2.4).
4. **Harmful bias / toxicity** — content-safety controls and bias/fairness evaluation across affected groups; mandatory where fair-lending applies (NIST 600-1 §2.3, §2.6).
5. **RAG grounding** — outputs grounded in an approved source allow-list; groundedness measured; citations required (NIST 600-1 §2.8).
6. **Human oversight** — defined human-in-the-loop with documented friction at consequential decision points (NIST 600-1 §2.7).
7. **Third-party foundation-model risk** — vendor due diligence, AIBOM, provenance, and no-training confirmation for the data classes used (NIST 600-1 §2.12).
8. **Ongoing monitoring / drift** — production monitoring with drift, hallucination-rate, and override analysis, with alerting (NIST AI RMF — MANAGE).

14. Exceptions and Reporting

Exceptions require documented approval and compensating controls. MRM reports inventory completeness, tiering distribution, open high-severity findings, and GenAI-track coverage to the Board Risk Committee quarterly.

This Policy is the standard against which AI use cases are assessed. It is descriptive of the Bank's control expectations and does not itself constitute regulatory guidance.